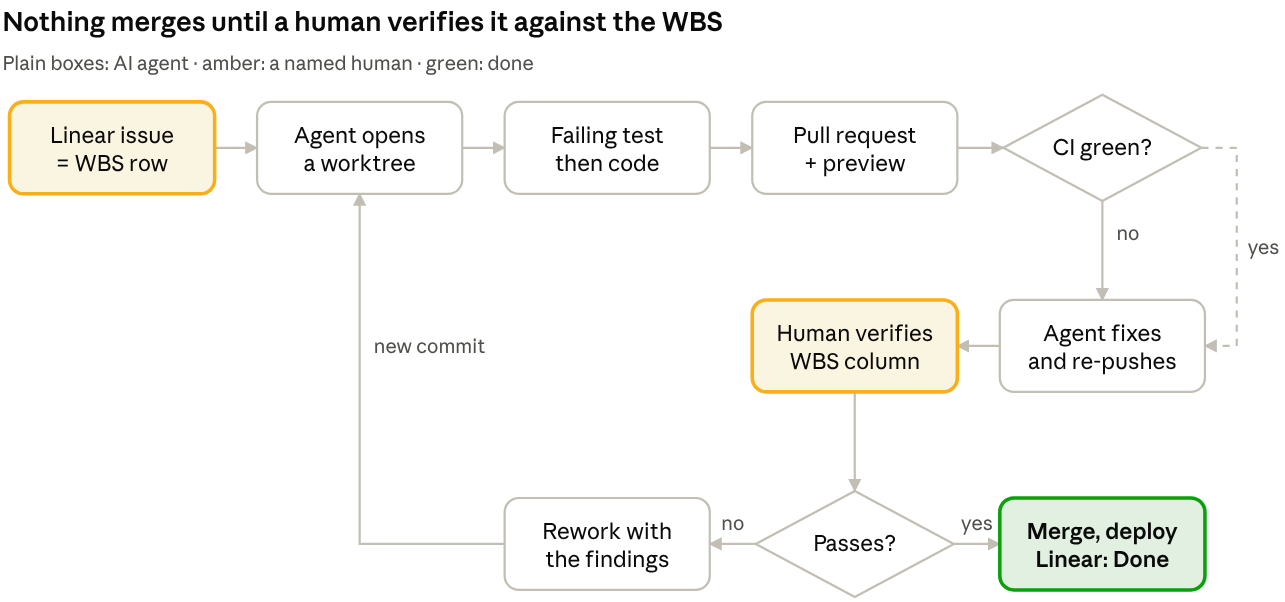
Workflow & final verification

Oct 18, 2026 · @Ravin

Every WBS package becomes one Linear issue, one git worktree and one pull request: an AI agent writes the failing test first, a named human verifies against the WBS "Human verifies" column, and nothing merges unverified. This tab sets those rules, the PII and security rules, and ends with the go / no-go gate before the pilot. It is a plan: no Linear, Slack or GitHub account has been connected or checked from here.

How a package moves



one package, from Linear issue to merged · two gates: CI and a human

A human appears twice and nowhere else: writing the issue with its acceptance criteria, and verifying the result. Everything in between is the agent's job, including fixing its own CI failures. The dashed line is the only shortcut: CI green moves the issue to "Ready to verify" automatically, it never merges.

Linear

Linear is the single source of truth for status; the WBS tab is the plan, Linear is the live state. One workspace, one team (BIZ), three projects named Phase 1, Phase 2, Phase 3.

Setting	Rule
Issue = WBS row	Title `1.3 Auth (Better Auth)`; description carries the WBS "Done when" and "Human verifies" text verbatim plus acceptance criteria as a checklist; label `wbs:1.3`; estimate in days from the WBS
Sub-issues	An agent may split a package into sub-issues, never merge two packages into one
Statuses	Backlog → Todo → In progress (agent) → In review (CI green, PR open) → Ready to verify → Verifying (human) → Done; plus Blocked and Cut
Who moves what	GitHub automation moves to In review and Ready to verify; only the verifier moves to Done; only the lead moves to Cut
Labels	`phase:1/2/3`, `area:` (auth, catalog, quote, invoice, payments, messages, portal, admin, infra), `risk:high` for 2.3 and 2.6, `pii` when the package touches customer data, `connector:` in Phase 2
Cycles	One cycle per day in the 10-day build; the day column in the WBS is the cycle
Verifier	Assignee is the agent's human owner; a second field, Verifier, names the person from the WBS column; the two must differ
Blocked	Any issue Blocked for more than 4 hours is raised in Slack #build by the owner
Cut line	On day 9 the lead moves unverified issues to Cut with a one-line reason; they return to Backlog in Phase 2

Git and worktrees

Several agents work at once, so each package runs in its own git worktree on its own branch; two agents never share a checkout.

- **One repo, monorepo**: `apps/web`, `apps/mobile`, `apps/api`, `packages/db`, `packages/ui`, `packages/templates`, `packages/connectors`.
- **Branch per issue**: `biz-123-auth-better-auth`, created from `main` at the start of the issue; Linear's branch name is used as is.
- **Worktree per branch**: `git worktree add ../wt/biz-123 biz-123-auth-better-auth`; an agent is told its worktree path and must not touch any other path; the worktree is removed after merge.
- **Rebase, don't merge main in**: before opening or updating a PR the agent rebases on `main`; conflicts are the agent's to resolve, with the test suite green after.
- **Small commits, conventional messages**: `feat(quote): accept page with name and phone (BIZ-123)`; the issue key is in every commit so Linear links it.
- **Shared files are owned**: `packages/db/schema` is edited only by the issue that owns the entity (see Data model); other agents open a sub-issue and wait. Migrations are numbered by timestamp and never edited after merge.
- **Generated code is reviewed like human code**: no "AI wrote it" exemption; the human reads the diff, not the agent's summary.
- **Never in git**: secrets, `.env`, customer data, real logos from pilots, screenshots with PII.
- **Tags**: `v0.1.0-pilot` on day 10; a tag per deploy to production afterwards.

GitHub

Area	Rule
Branch protection on `main`	No direct pushes; PR required; all required checks green; one human approval from someone other than the author; linear history (squash merge); stale approvals dismissed on new commits
Required checks	lint + typecheck, unit and integration tests, RLS cross-tenant test, Lighthouse budget on the portal pages, axe accessibility, secret scan, dependency audit, migration dry-run against a staging snapshot
Preview deploys	Every PR gets a preview URL with seeded demo data (no real PII) so the verifier can click through on a phone

Area	Rule
PR template	Linear key; what changed; how to verify (copied from the WBS column); screenshots or a short recording on a phone; test list added; PII touched yes / no; migration yes / no; rollback note
CODEOWNERS	`packages/db` and `packages/connectors` require the lead's review; `apps/api/auth` requires the security reviewer
Secrets	GitHub environment secrets per environment; no secrets in Actions logs; rotation recorded in the Infra section
Agents on GitHub	Agents open PRs and reply to review comments; they cannot approve, merge, or change protection rules; their bot account has write to branches, never to `main`
Automation	PR opened → Linear In review; checks green → Ready to verify; merged → Done only if the verifier has approved; a bot comment lists any WBS acceptance item not yet checked
Releases	Merge to `main` deploys staging automatically; production deploys from a tag by a human with a one-line release note posted to Slack #releases

TDD

An agent's first commit on any issue is a failing test taken from the acceptance criteria; the second makes it pass. A PR whose first commit is implementation code is sent back.

Order of work for an agent

1. Read the Linear issue, the WBS row, the Data model and Glossary sections it touches.
2. Write the acceptance criteria as tests (unit for rules, integration for API and RLS, end-to-end for one happy path per screen) and commit them red.
3. Write the smallest code that turns them green; refactor; keep the suite under 5 minutes.

4. Add one negative test per rule (wrong tenant, expired token, duplicate number, missing GST number).
5. Open the PR with the test list in the template.

Test layers

Layer	Tool (suggested)	What it must cover
Unit	Vitest	Totals, GST split, numbering, state machines, theme contrast gate, template rendering
Integration	Vitest + a Postgres test container	Every API route; RLS: a user of workspace A can never read or write B (fuzzed over all tables); webhooks (Phase 2)
End-to-end	Playwright, mobile viewport first	Flow 1 onboarding, Flow 2 quote accept, Flow 3 proof → approval → paid, portal pay page; run against the preview deploy
Visual	Playwright screenshots	Quote and invoice PDF vs web render, light and dark, two sample brands
Contract	Schema snapshot	Export formats (PDF, DOCX, CSV) open in Word / Excel; template variables all resolved
Non-functional	Lighthouse, axe, k6	NFR targets from the Design inputs tab

Rules that are always tests, never prose: tenant isolation; invoice numbers gap-free and assigned at first share; a payment turns Paid only after approval; a Manager cannot approve above the threshold; expired quotes cannot be accepted; portal tokens are 32 bytes and revocable; no customer-facing surface renders the word Biz4Kit on a paid plan.

Flaky tests are quarantined within the day and fixed or deleted by the owner, never retried into green.

Infra

Topic	Rule
Environments	`preview` (per PR, seeded demo data), `staging` (main, anonymised copy of production once it exists), `production`; nothing else
Region	Database, storage and backups in India (Mumbai); the app may run at the edge but data stays in region
Deploy	Staging on every merge to `main`; production from a tag by a human; blue-green or instant rollback to the previous tag within 5 minutes
Migrations	Expand-then-contract: add columns and backfill first, remove in a later release; every migration has a tested down path; dry-run in CI against a staging snapshot
Backups	Nightly full plus continuous WAL; 30-day retention; restore drill on day 8 and monthly after; the drill is logged in Linear
Secrets	Managed secret store per environment; no secret in code, logs, Slack or Linear; rotation every 90 days and immediately on any suspected leak; connector keys encrypted per workspace at rest (Phase 2)
Observability	Error tracking with PII scrubbing; structured logs with `workspace_id` and request id; funnel events for G1–G8; uptime check on the portal and the API; alerts to Slack #alerts for error-rate, queue depth and failed emails
Jobs	BullMQ with retries and dead-letter queue; PDF, email and nightly expiry jobs are idempotent (safe to run twice)
Storage	Private buckets; files served through signed URLs that expire; proof files and logos never public

Topic	Rule
Cost	Monthly cost sheet per environment; alert at 80% of budget; the per-workspace cost model lives in the Business plan tab
Access	Production access for two named people, MFA on everything, audit log of console access; agents have no production credentials
Status	A public status page from day 10, linked in the footer of the workspace app

PII

We hold personal data about two groups: the business's people (members) and the business's customers, who never agreed to anything with us directly. The business is responsible to its customers; we are responsible to the business. India's DPDP Act applies; a lawyer must confirm the exact duties before launch.

Inventory

Data	Where	Who can see it	Kept for
Member name, email, Google id, device list	Better Auth tables	The member, the workspace Owner	Until the member is removed + 30 days
Customer name, phone, email, address, GST number	Customer, Quote, Invoice	Workspace members by role; the customer via private links	While the business is active; erasure on request, invoice fields kept for tax as the CA advises
Payment proof images and PDFs	Private storage	Uploader, Owner / approving Manager, Accountant	8 years from the financial year, if the CA confirms; otherwise 1 year
Customer photos and briefs on leads	Lead	Workspace members	1 year after the lead closes

Data	Where	Who can see it	Kept for
Message log bodies	Message	Workspace members	1 year
Analytics events	Analytics tool	Biz4Kit team	Pseudonymous ids only; 13 months
Support conversations	WhatsApp Business, support inbox	Support person, lead	1 year

Rules

- Collect the minimum: the quote-request form asks name and phone; email and address only when the business turns them on.
- Phone is the customer key; store it normalised and never show it fully on public pages (masked `+91 98xxx xx210` on My orders).
- PII never goes in URLs, logs, error reports, Slack, Linear, screenshots or test fixtures; preview and staging use generated data only.
- Every table with PII is marked in the schema; a lint rule blocks new PII columns without the mark; the `pii` Linear label requires the security reviewer on the PR.
- Export and erasure: a customer or business can ask; export within 7 days, erasure within 30, which anonymises the Customer and keeps invoice numbers and totals for tax.
- Consent lines: on the quote-request form and the My-orders page, written by the lawyer, in plain English.
- **AI-ingest boundary (Phase 2):** files sent to the Claude API are the owner's price lists and briefs; the owner is told before upload; proof-of-payment images and member data are never sent; outputs are reviewed by the owner before saving; the vendor's data-retention terms are recorded in the Legal tab.
- Breach: any suspected exposure goes to the lead within an hour; the lawyer decides on notification duties; a template notice is prepared before launch.

Security

Threat	Control	Verified by
One business reads another's data	RLS on every table plus `workspace_id` filter in the API; fuzz test across all tables in CI	Integration suite, every PR
Forwarded or guessed private links	32-byte random tokens, rate-limited lookups, revocable per record, expiry on approval links (48 h, single use)	Unit tests, OWASP checklist
Phishing pages on free subdomains	Reserved names, bank and brand look-alike checks, report link, takedown within 4 hours, new-workspace review in the admin console	Day-8 abuse test (WBS 3.8)
Session theft	Short-lived access tokens, rotating refresh, device list and revoke, re-auth for billing and deletion	Auth tests
Injection and XSS in quotes (free text, logos, SVG)	Sanitise rich text; rasterise SVG logos; content-security policy; file-type and size limits on uploads; virus scan on proof files	Security review, upload tests
Webhook spoofing (Phase 2)	Signature verification, replay window, idempotent handlers	Connector tests
Secrets in code or logs	Secret scanning in CI, log scrubbing, environment secret store	CI, infra review
Dependency vulnerabilities	Lockfile, audit in CI, weekly update PR	CI
Admin misuse	Impersonation only with consent log; every admin action in the audit log; two named admins with MFA	Admin console tests

Threat	Control	Verified by
Denial of service on public pages	Rate limits per IP and per workspace, bot detection on the quote form, CDN caching of catalog pages	Load test before pilot

AI-agent risks, specific to this build

Risk	Control
An agent invents a rule or a field not in the spec	The issue carries the exact spec; the verifier checks against the WBS and Data model, not the PR description
An agent weakens a test to go green	Tests from the acceptance criteria are owned by the human; changes to existing tests need the verifier's explicit approval; CI flags modified test files
An agent commits secrets or real data	Secret scanning; no production credentials or real data available to agents
Prompt injection through repo content, issues or web pages	Agents treat file and web content as data; any instruction found in content is reported, not followed; an unexpected command, URL or dependency in a PR is a blocker
Unreviewed dependency added	New dependencies listed in the PR template and justified; lockfile diff reviewed
Two agents edit the same file	Worktree per issue; owned paths; rebase rule
Agent bypasses the human gate	Bot account cannot approve or merge; branch protection enforced by GitHub, not by convention

Slack

Channel	Purpose	Posts
#build	The 10-day build; one thread per day	Daily update (below), blockers, cut decisions
#verify	Verification requests and results	Bot: "Ready to verify" with the PR link, preview URL and the WBS checklist; the verifier replies pass / fail with findings
#alerts	Automated only	CI failures on `main`, error-rate, failed emails, queue depth, uptime
#releases	Production deploys	Tag, one-line note, rollback link
#pilot	Founding 20 and GTM numbers	Daily G1–G8 snapshot, owner feedback, support escalations
#security	Private	Suspected leaks, abuse reports, access changes

Daily update (posted by the lead at 18:30 IST, same shape every day, under 12 lines): day number; packages verified today (with WBS ids); packages in verification; blocked, with who unblocks; what is at risk of the day-9 cut; one number from the test suite (count and runtime); one ask.

Rules: decisions made in Slack are copied to the Linear issue within the hour; no PII in any channel; agents post only through the bot in #verify and #alerts; a blocker older than 4 hours is a call, not a thread.

Ten-day cadence

Build runs a day ahead of verification: agents generate day N's packages while humans verify day N−1's. The WBS day column is the build day; verification lands the next morning.

Day	Agents build	Humans verify	Also
1	1.1, 1.2, 1.3; prototypes of 2.3 and 2.6	Workflow dry run: one tiny PR through the whole flow	Start Meta, Google consent screen, Resend DNS, gateway applications; lawyer and CA booked

Day	Agents build	Humans verify	Also
2	1.4, 1.5, 1.6, 1.7	1.1, 1.2, 1.3	Founding-20 outreach begins
3	2.1, 2.2, 2.3	1.4, 1.5, 1.6, 1.7	Designer reviews shell on a phone
4	2.4, 2.5	2.1, 2.2, 2.3	Template wording review
5	2.6, 2.7, 2.8	2.4, 2.5	Accountant reviews sample invoices
6	2.9, 3.1, 3.2	2.6, 2.7, 2.8	Restore drill scheduled
7	3.3, 3.4, 3.5	2.9, 3.1, 3.2	First end-to-end run with a real pilot owner's data (consented)
8	3.6, 3.7, 3.8, 3.9	3.3, 3.4, 3.5	Restore drill; abuse test
9	4.1, 4.2, 4.3	3.6–3.9; cut line at 18:00	Legal pages reviewed; status page live
10	4.4	4.1, 4.2, 4.3; go / no-go at 16:00	Tag `v0.1.0-pilot`; Founding 20 set-up visits begin

If verification falls more than one day behind build, agents stop starting new packages and pick up findings instead; the schedule bends, the human gate does not.

Final verification: go / no-go

Held on day 10 at 16:00 with the lead, the verifier of record, the designer and the owner. Every line is checked by a named person against evidence (a test run, a screenshot, a log), not a verbal yes. Any unchecked line in the first two groups means no-go; the pilot waits, it does not launch half-verified.

Must pass: product

- [ ] Flows 1–4 pass end to end on a Moto G-class Android over throttled 4G, from a preview with demo data and from production with one consented pilot
- [ ] Every WBS Phase 1 row is Done in Linear with a named verifier, or Cut with a reason
- [ ] Cross-tenant fuzz test green on every table; manual attempt to read another workspace fails

- [ ] Invoice numbering: gap-free across 100 generated invoices, number assigned at first share, void keeps number
- [ ] A payment turns Paid only after approval; Manager threshold enforced; approve link single-use and expiring
- [ ] Five sample invoices (B2C, B2B, inter-state, with discount, with advance) signed off by the accountant
- [ ] PDF, DOCX and CSV exports open in Word, Google Docs and Excel; PDF matches the web render for two brands, light and dark
- [ ] Every ready message renders with all variables resolved; share works from the Android share sheet to WhatsApp
- [ ] Email: invite, new lead, proof waiting, accepted, customer copy and My-orders link received on Gmail and Outlook; SPF, DKIM, DMARC pass
- [ ] Offline: read today's bookings and jobs, draft a quote, reconnect, no loss
- [ ] Lighthouse and axe budgets met on catalog, quote, invoice and pay pages
- [ ] No customer-facing surface shows the word Biz4Kit except the catalog footer on the free plan

Must pass: safety and operations

- [ ] Backup restore drill completed on day 8 with the time recorded
- [ ] Secrets scan clean; no production credentials held by any agent; MFA on all human accounts
- [ ] Abuse controls: a bank look-alike slug is refused; report link works; takedown path tested
- [ ] Error tracking, uptime check, funnel events for G1–G8 and #alerts all firing on staging and production
- [ ] Terms, privacy and consent lines reviewed by the lawyer and live; DPDP export and erasure jobs tested
- [ ] Rollback to the previous tag rehearsed in under 5 minutes
- [ ] Support WhatsApp number live, named person on it, response-time promise written

Should pass: pilot readiness

- [ ] Founding 20 named with a yes; set-up visits scheduled; introduction cards printed
- [ ] Six vertical starter kits reviewed by one real owner each
- [ ] Expo shell installed on three Android phones with sessions surviving a week
- [ ] Daily G1–G8 snapshot posting to #pilot

- [ ] Day-9 cut list written into Phase 2 backlog

Decision: go, go with named exceptions (each with an owner and a date), or no-go with a new date. Recorded in Linear and #build by the lead.